Security Operations Center (SOC) Monitoring Lab Report

Name: Tanay Sengupta
Course: Security Operations / SOC Fundamentals
Environment Used: Kali Linux, ELK Stack (Elasticsearch, Logstash, Kibana), Snort IDS, Nessus, Hydra, Metasploitable2, Windows 11
Submission Date: 13 March 2026

1. Introduction

A **Security Operations Center (SOC)** is a centralized facility responsible for monitoring, detecting, analyzing, and responding to cybersecurity incidents within an organization. SOC teams continuously analyze logs, network traffic, alerts, and endpoint data to identify suspicious activities and prevent security breaches.
The purpose of this lab was to simulate a **mini SOC environment** using open-source security tools. The environment included ELK Stack for log monitoring, Snort for intrusion detection, Hydra for brute-force simulation, and Nessus for vulnerability scanning.
The lab demonstrates how SOC analysts monitor logs, detect malicious activities, investigate alerts, and respond to potential security incidents.

2. SOC Fundamentals and Operations

Purpose of a SOC

The main objective of a Security Operations Center is to **protect an organization's information systems by continuously monitoring and responding to threats**.
SOC operations focus on:

- Proactive threat detection
- Continuous system monitoring
- Incident response and containment
- Security event correlation
- Threat intelligence analysis

SOC teams operate 24/7 to ensure rapid detection and mitigation of security incidents.

Roles in a SOC

SOC teams consist of multiple roles organized in tiers.

Tier 1 Analyst (Monitoring Analyst)

Tier 1 analysts are responsible for monitoring alerts generated by security tools such as SIEM systems.
Responsibilities include:

- Monitoring dashboards and alerts
- Performing basic log analysis
- Escalating suspicious events to higher-level analysts

Tier 2 Analyst (Incident Responder)

Tier 2 analysts investigate alerts escalated by Tier 1 analysts.
Responsibilities include:

- Analyzing logs and security alerts
- Investigating suspicious activity
- Identifying Indicators of Compromise (IOCs)

Tier 3 Analyst (Threat Hunter)
Tier 3 analysts perform advanced threat analysis and proactive threat hunting.
Responsibilities include:

- Malware analysis
- Advanced forensic investigations
- Creating detection rules
- Threat intelligence analysis

SOC Manager
The SOC manager oversees SOC operations and coordinates incident response.
Responsibilities include:

- Managing SOC teams
- Developing security policies
- Coordinating incident response activities

3. Security Monitoring Basics

Security monitoring is the process of continuously observing system activity to detect malicious behavior.

Objectives of Security Monitoring

Security monitoring aims to detect:

- Unauthorized access attempts
- Suspicious system activity
- Malware infections
- Network anomalies
- Security policy violations

By monitoring logs and network traffic, SOC analysts can detect potential attacks early.

Security Monitoring Tools

Several tools are used for monitoring security events.

Tool	Purpose
Elastic SIEM	Log monitoring and visualization
Wireshark	Network packet analysis
Snort	Intrusion detection
Nessus	Vulnerability scanning

Key Monitoring Metrics

False Positives

False positives occur when benign activities are incorrectly flagged as malicious.

False Negatives
False negatives occur when malicious activities go undetected.

Mean Time to Detect (MTTD)
MTTD measures how quickly a security team detects a security incident.
Lower MTTD indicates better monitoring effectiveness.

4. Log Management Fundamentals

Log management is essential for detecting and investigating security incidents.

Log Lifecycle

The lifecycle of logs consists of several stages. Stated below

Log Collection

- Logs are collected from systems, applications, and network devices.

Log Normalization

- Logs are converted into standardized formats such as JSON or CEF.

Log Storage

- Logs are stored in centralized databases such as Elasticsearch.

Log Analysis

- Logs are analyzed to detect patterns or anomalies.

Log Retention

- Logs are stored for a defined period for compliance and forensic analysis.

Common Log Types

Common logs used in SOC analysis include:

- Windows Event Logs
- Linux Authentication Logs
- Syslog logs
- Web server logs

In this lab environment, Linux authentication logs were collected from:
`/var/log/auth.log`

Log Collection Pipeline

A log collection pipeline was implemented using **Logstash and Elasticsearch**.
Logstash collected authentication logs from Kali Linux and forwarded them to Elasticsearch for indexing and analysis.

Logstash Configuration Used

```
input {
  file {
    path => "/var/log/auth.log"
    start_position => "beginning"
    sincedb_path => "/dev/null"
    type => "authlog"
  }
}

filter {
  if "Failed password" in [message] {
    mutate {
      add_tag => ["ssh_failed_login"]
    }
  }
```

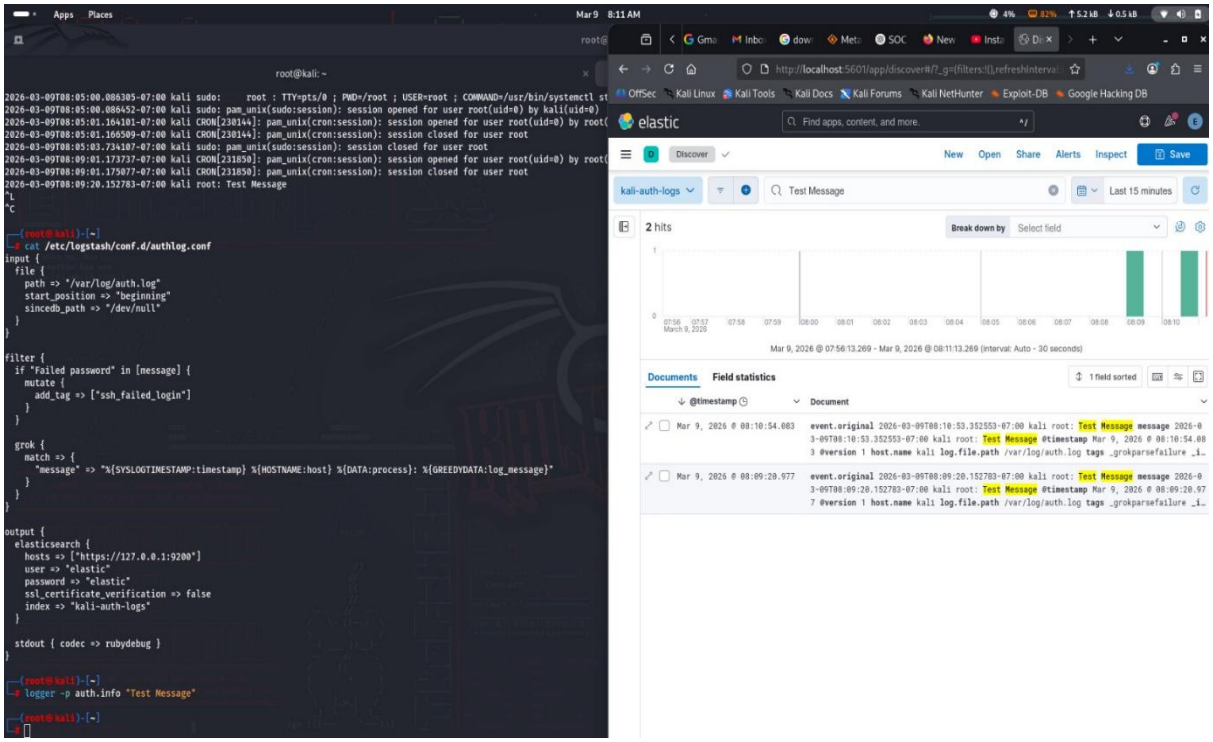
```
grok {
    match => {
      "message" => "%{SYSLOGTIMESTAMP:syslog_timestamp} %{HOSTNAME:host}
%{DATA:process}: %{GREEDYDATA:log_message}"
    }
  }

  date {
    match => ["syslog_timestamp", "MMM  d HH:mm:ss", "MMM dd HH:mm:ss"]
  }
}

output {
  elasticsearch {
    hosts => ["https://127.0.0.1:9200"]
    user => "elastic"
    password => "elastic@123"
    ssl_certificate_verification => false
    index => "kali-auth-logs"
  }

  stdout { codec => rubydebug }
}
```

Log Pipeline Testing

A test log entry was generated using:

- `logger "Test message"`

The test message appeared in Kibana, confirming the pipeline was working correctly.



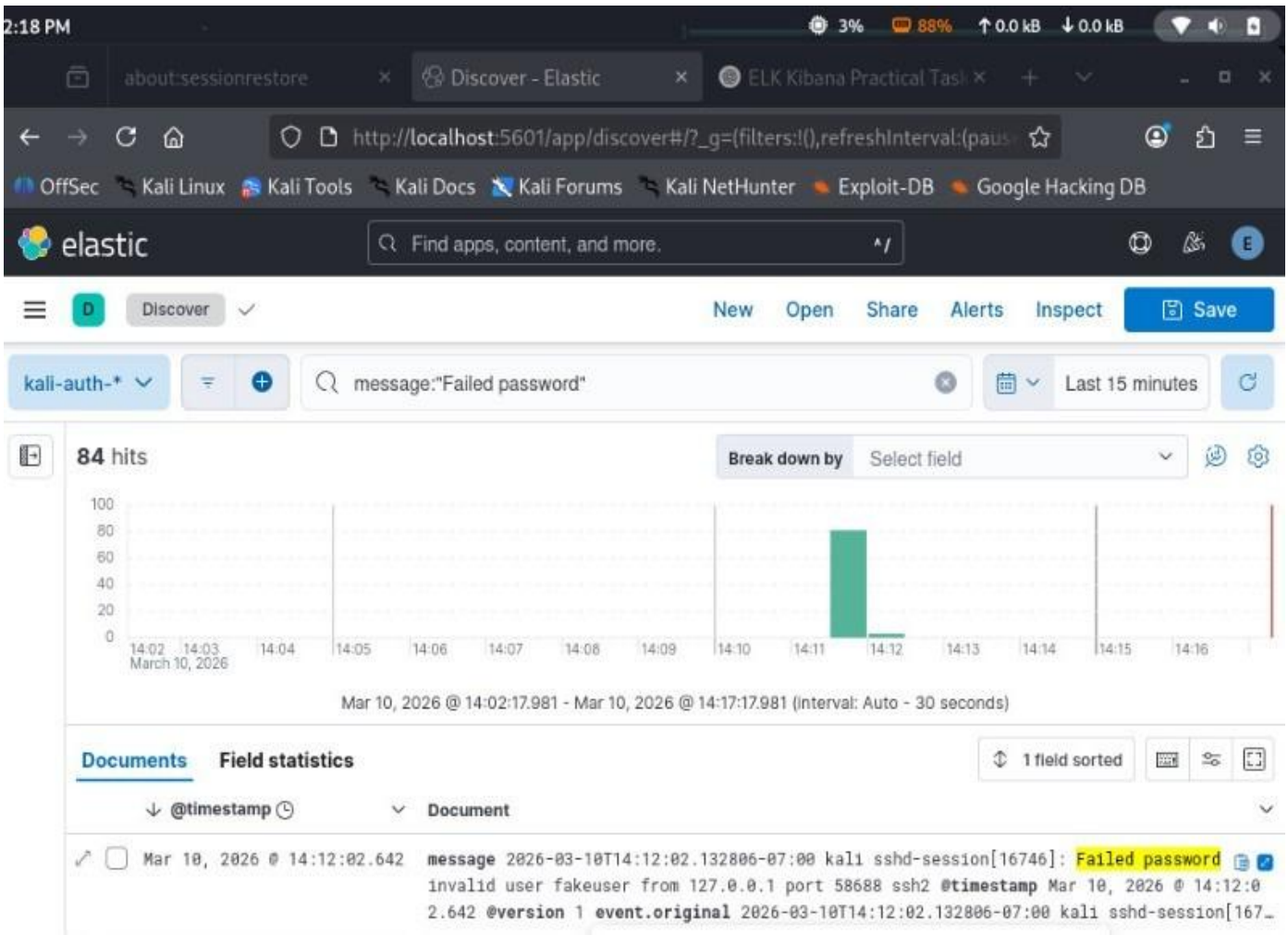
Log Analysis & Log Normalization Practice

Log analysis is an important task for SOC analysts.
Authentication logs were monitored to detect suspicious login attempts.
Unauthorized login attempts were simulated using:

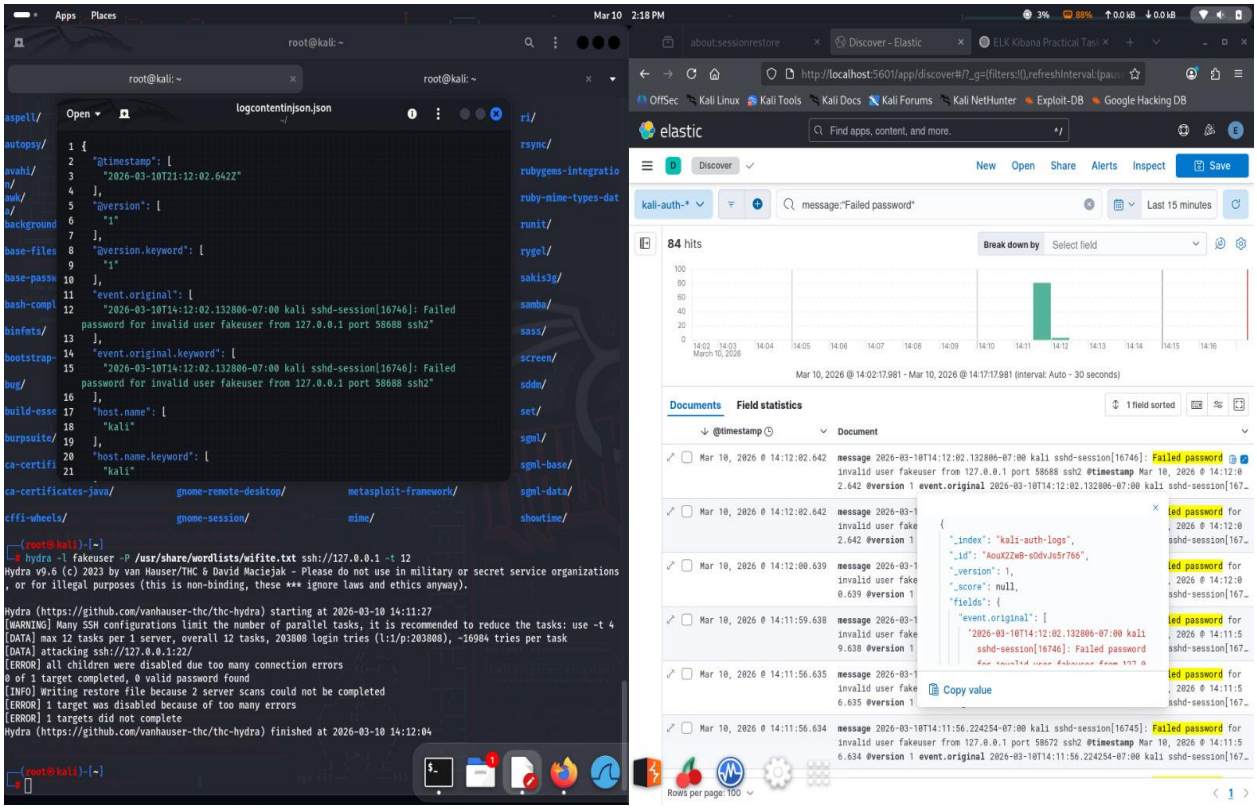
- `ssh fakeuser@localhost`

Multiple incorrect passwords were entered to generate failed authentication logs.
These logs were collected and analyzed using Kibana.
Kibana query used:

- `message: "Failed password"`



Log Normalization:
Log normalization is the process of converting logs from different sources into a standardized and structured format so they can be easily analyzed by SIEM systems. In this lab, Logstash was used to parse raw authentication logs from `/var/log/auth.log` using Grok filters, extracting fields such as timestamp, hostname, process name, and message. This normalization allows efficient searching, correlation, and visualization of security events in Kibana.
Here the json is extracted into a file



Browser History Analysis
Browser history can provide evidence of suspicious web activity.
Eric Zimmerman's forensic tools such as **LECmd** can be used to analyze browser artifacts.
These tools parse browser databases and extract information such as:

- Visited URLs
- Timestamps
- User activity

Example investigation involved searching for visits to:
`http://test.com`
This helps identify potentially malicious browsing behavior.

5. Security Tools Overview

SOC teams use various tools to detect and analyze threats.

SIEM Tools

SIEM tools collect logs from multiple sources and analyze them in real time.

Examples include:

- Splunk
- Elastic SIEM
- IBM QRadar

EDR Tools

Endpoint Detection and Response (EDR) tools monitor endpoint devices for suspicious behavior.

Example:

- CrowdStrike Falcon

IDS/IPS

Intrusion Detection Systems monitor network traffic for malicious activity.

Example:

- Snort

Vulnerability Scanners

Vulnerability scanners detect security weaknesses in systems.

Example:

- Nessus

Snort Rule Testing

Snort was configured to detect malicious HTTP requests.

Example rule used:

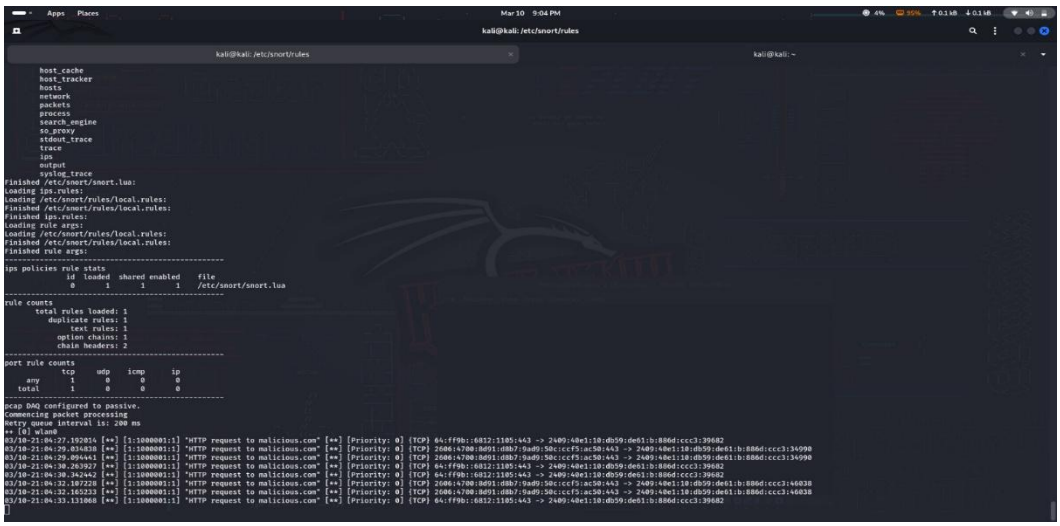
```
alert tcp any any -> any 80 (msg:"Malicious Domain";
content:"malicious.com"; http_uri; sid:1000001;)
```

The rule detects HTTP requests containing the domain **malicious.com**.

Testing command used:

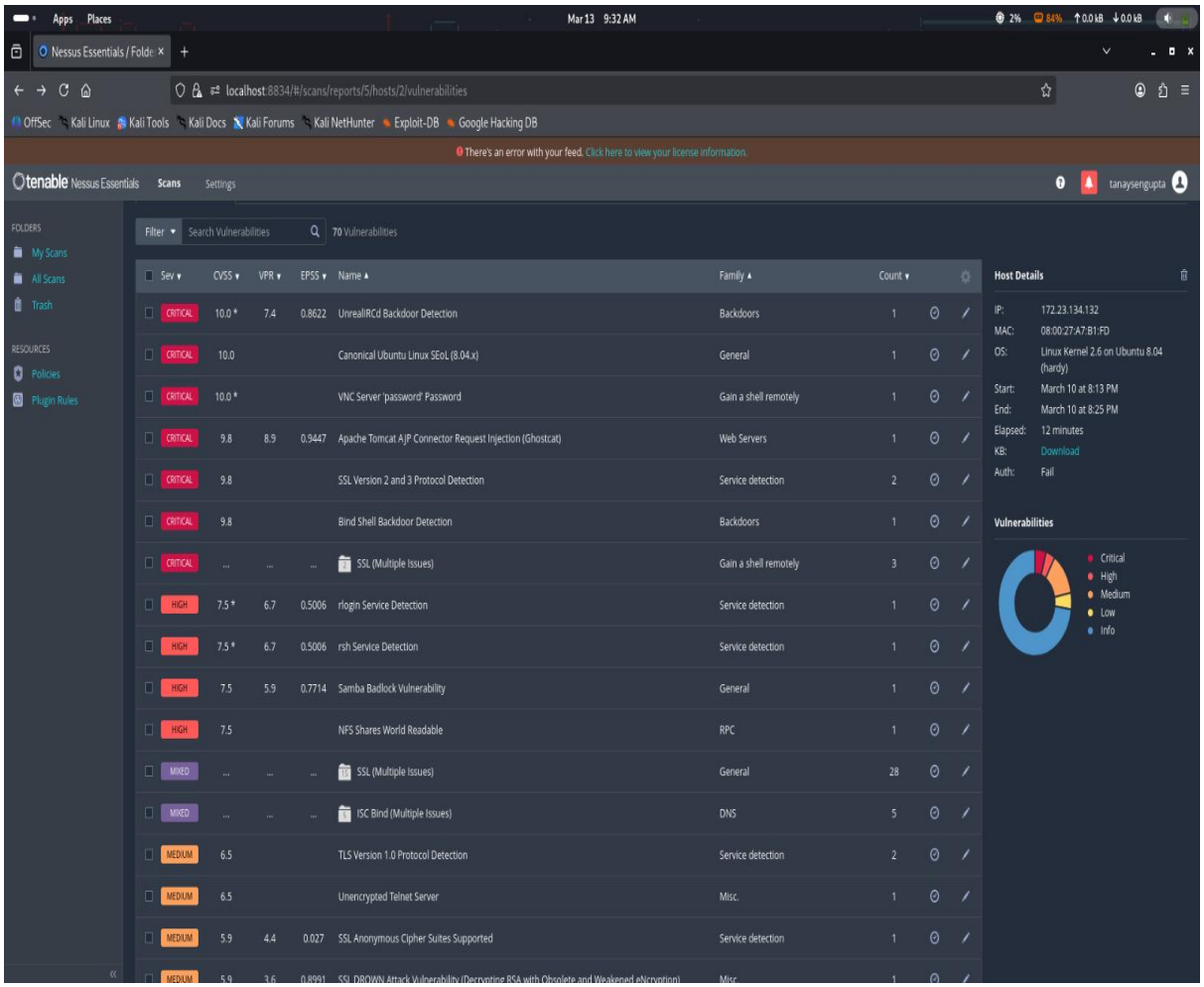
```
curl http://malicious.com
```

When the request was sent, Snort generated an alert indicating malicious activity.



Vulnerability Assessment Using Nessus

A vulnerability scan was performed using **Nessus Essentials**.
Target machine:
Metasploitable2
Target IP:
`172.23.134.132`
Scan type used:
`Basic Network Scan`



Due to the nature of the Nessus user account type (Nessus Essentials) scan report could not be fetched or exported

Nessus Scan Results

The scan identified several critical vulnerabilities.
Examples include:

Vulnerability	CVSS Score
vsFTPd Backdoor	10.0
UnrealIRCd Backdoor	10.0
Samba Remote Code Execution	9.8

These vulnerabilities allow attackers to gain unauthorized access or execute commands remotely.

Sev	CVSS	VPR	EPSS	Name	Family	Count
CRITICAL	10.0 *	7.4	0.8622	UnrealIRCd Backdoor Detection	Backdoors	1
CRITICAL	10.0			Canonical Ubuntu Linux SEoL (8.04.x)	General	1
CRITICAL	10.0 *			VNC Server 'password' Password	Gain a shell remotely	1
CRITICAL	9.8	8.9	0.9447	Apache Tomcat AJP Connector Request Injection (Ghostcat)	Web Servers	1
CRITICAL	9.8			SSL Version 2 and 3 Protocol Detection	Service detection	2
CRITICAL	9.8			Bind Shell Backdoor Detection	Backdoors	1
CRITICAL	...	...	...	SSL (Multiple Issues)	Gain a shell remotely	3
HIGH	7.5 *	6.7	0.5006	rlogin Service Detection	Service detection	1
HIGH	7.5 *	6.7	0.5006	rsh Service Detection	Service detection	1
HIGH	7.5	5.9	0.7714	Samba Badlock Vulnerability	General	1
HIGH	7.5			NFS Shares World Readable	RPC	1

6. Basic Security Concepts

CIA Triad (Confidentiality, Integrity, Availability):

The CIA Triad is a fundamental cybersecurity model used to guide the protection of information systems. It consists of three core principles: Confidentiality, Integrity, and Availability.

- Confidentiality ensures that sensitive information is accessible only to authorized users. Techniques such as encryption, authentication, and access control are used to prevent unauthorized access to data.
- Integrity ensures that data remains accurate and unchanged unless modified by authorized users. Methods such as hashing, digital signatures, and file integrity monitoring are used to protect data from unauthorized alteration.
- Availability ensures that systems, services, and data are accessible to authorized users whenever needed. This is maintained through system backups, redundancy, disaster recovery plans, and protection against attacks such as Denial-of-Service (DoS).

Together, these three principles form the foundation of modern cybersecurity and are essential for maintaining secure and reliable information systems.

Threat, Vulnerability, and Risk

Term	Definition
Threat	Potential attack
Vulnerability	Weakness in a system
Risk	Probability of a threat exploiting a vulnerability

Security Operations Workflow

Security Operations Center (SOC) teams follow a structured workflow to efficiently detect, analyze, and respond to security incidents. This workflow ensures that potential threats are handled systematically and that security teams can minimize the impact of cyberattacks.

Detection:

The detection stage involves identifying potential security incidents through monitoring systems such as SIEM platforms, intrusion detection systems (IDS), endpoint detection tools, and network monitoring tools. These systems continuously analyze logs, network traffic, and system behavior to identify suspicious activities such as failed login attempts, malware activity, or unusual network connections.

Triage:

Once an alert is generated, SOC analysts perform triage to determine the severity and priority of the alert. During this stage, analysts review the alert details, identify whether it is a false positive or a real threat, and classify the event based on its potential impact. High-risk alerts are escalated for further investigation.

Investigation:

In the investigation stage, analysts perform deeper analysis to confirm whether the alert represents a real security incident. This includes examining logs, correlating events across multiple systems, identifying indicators of compromise (IOCs), and analyzing system behavior to understand the nature and scope of the threat.

Response:

Once the threat is confirmed, the response phase begins. Security teams take actions to contain and eliminate the threat, such as blocking malicious IP addresses, isolating compromised systems, removing malware, and applying security patches. The goal of this stage is to minimize damage and restore normal system operations.

Incident Response Lifecycle

The **Incident Response Lifecycle** is a structured process used by security teams to detect, respond to, and recover from cybersecurity incidents. The most widely used framework for incident response is defined in **NIST SP 800-61 (Computer Security Incident Handling Guide)**. This framework provides a systematic approach that helps organizations manage security incidents efficiently while minimizing damage and restoring normal operations.

The lifecycle consists of several stages:

Preparation:

The preparation phase focuses on establishing the necessary tools, policies, and procedures required to respond to security incidents. This includes deploying monitoring tools such as SIEM systems, defining incident response policies, training security personnel, and maintaining updated system backups. Proper preparation ensures that organizations are ready to handle incidents quickly and effectively.

Identification:

In this stage, potential security incidents are detected and verified. Alerts generated by monitoring systems such as SIEM, IDS, or endpoint security tools are analyzed to determine whether they represent real security threats. Analysts examine logs, system activity, and indicators of compromise to confirm whether an incident has occurred.

Containment:

Once an incident is confirmed, containment measures are implemented to prevent the threat from spreading further within the network. This may involve isolating compromised systems, blocking malicious IP addresses, disabling affected user accounts, or restricting network access. The goal is to limit the damage caused by the attack.

Eradication:

During the eradication phase, the root cause of the incident is removed from the system. This may involve

deleting malware, patching vulnerabilities, removing unauthorized user accounts, or reconfiguring security controls. The objective is to completely eliminate the threat from the environment.

Recovery:

In the recovery stage, systems are restored to normal operation. This may include restoring data from backups, reconnecting isolated systems to the network, and verifying that systems are functioning correctly. Continuous monitoring is often performed during this stage to ensure that the threat does not reappear.

Lessons Learned:

The final stage focuses on reviewing the incident to improve future security practices. Security teams analyze what happened, how the attack occurred, and how the response process could be improved. This stage often results in updates to security policies, detection rules, and monitoring strategies.

Documentation Standards

Security incidents must be documented for auditing and investigation.

Example documentation template:

Date	Source IP	Event	Description	Action Taken
10-03-2026	127.0.0.1	Failed Login	Unauthorized SSH login attempt	Monitored

Documentation improves incident response processes and helps maintain compliance.

Windows Event Viewer – Failed Login and Brute-force Detection

Windows Event Viewer is a built-in tool used to monitor and analyze system logs generated by the Windows operating system. It records important system events such as logins, application activity, and security alerts. SOC analysts often use Event Viewer to detect suspicious activities including unauthorized login attempts.

In this lab, Windows Event Viewer was used to identify failed login attempts by filtering **Security logs** for a specific event ID.

The **Event ID 4625** represents a **failed logon attempt**. This event is generated when a user attempts to log in to a Windows system with incorrect credentials or when an unauthorized login attempt occurs.

By analyzing Event ID 4625, SOC analysts can detect potential brute-force attacks or unauthorized access attempts.

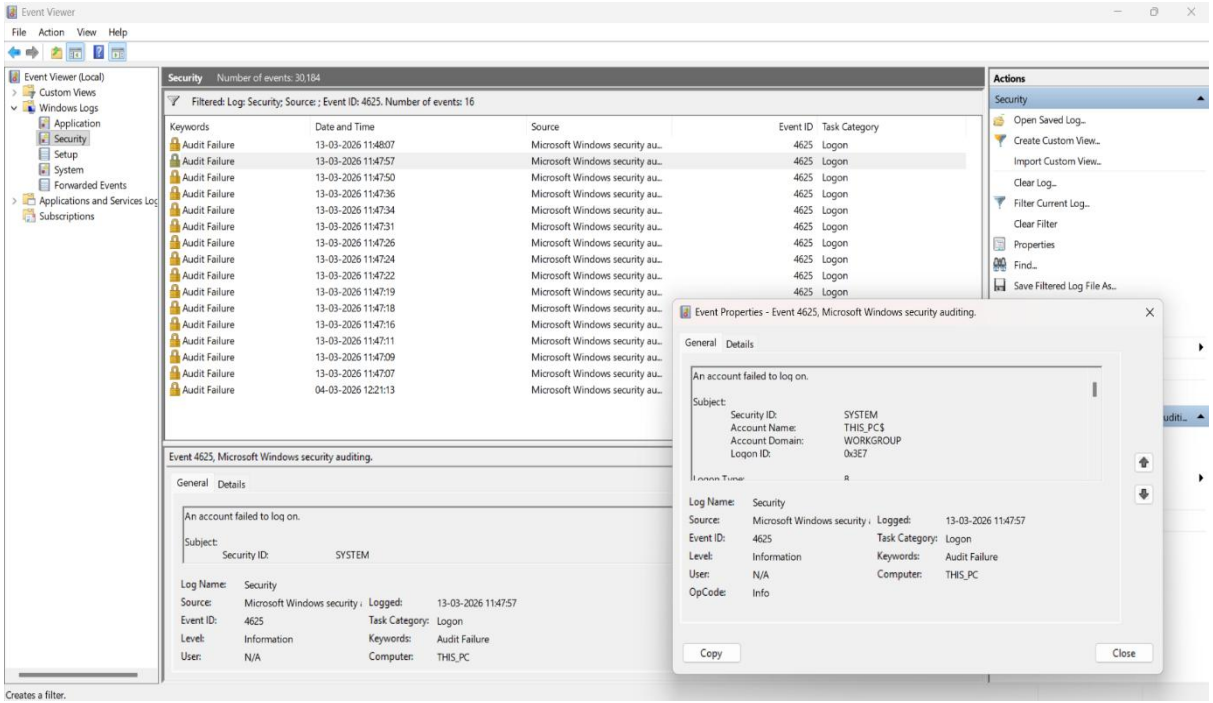
To view these logs, the following steps were performed:

1. Open **Windows Event Viewer**.
2. Navigate to **Windows Logs → Security**.
3. Apply a filter for **Event ID 4625**.
4. Review the logs to identify failed login attempts.

The event details provide important information such as:

- Username used during the login attempt
- Source IP address
- Timestamp of the event
- Failure reason

These details help SOC analysts determine whether the login attempts are legitimate errors or part of a brute-force attack.



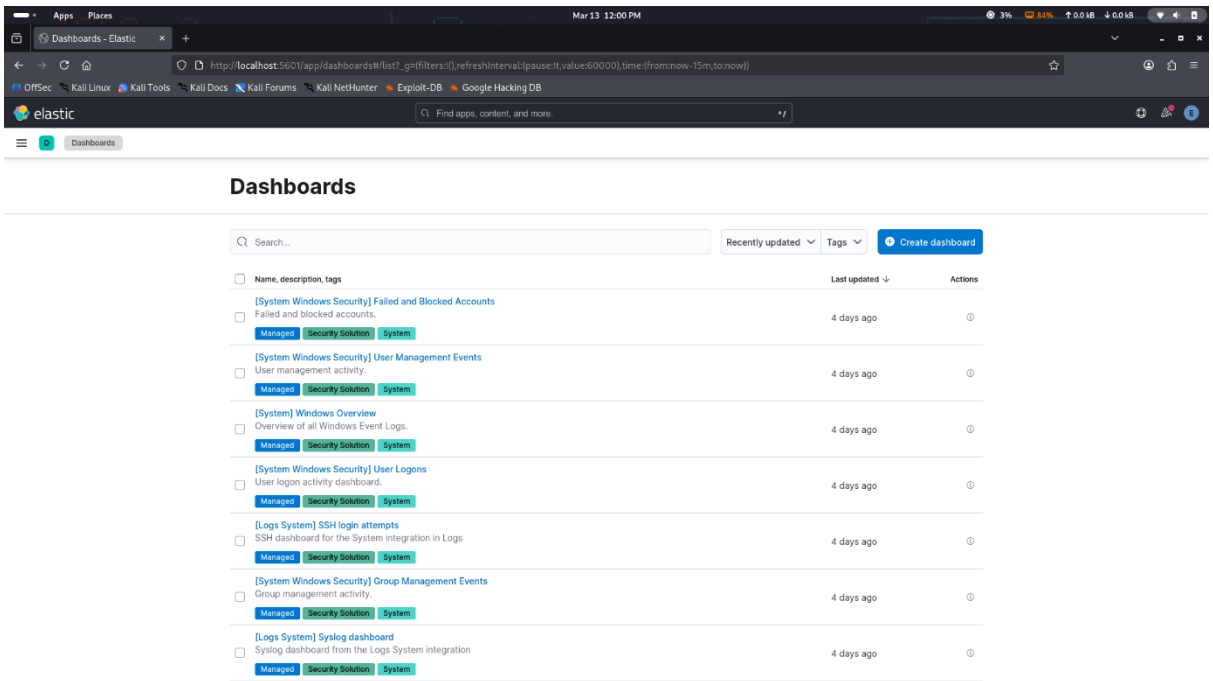
Monitoring Dashboards

Kibana dashboards were created to visualize security events.

Dashboards included:

- Top source IP addresses generating alerts
- Authentication failure trends
- System activity logs

These dashboards help analysts quickly detect abnormal behavior.



Learning Sources / References

- **NIST SP 800-61** – Framework for incident response lifecycle and security incident handling.
- **MITRE ATT&CK Framework** – Used to understand attacker tactics and techniques in SOC monitoring.
- **Elastic SIEM Documentation** – Reference for log analysis, Kibana queries, and alert rule configuration.
- **Boss of the SOC (BOTS) Datasets** – Used as examples of real-world security attack scenarios.
- **SANS Incident Handler's Handbook** – Guide for incident documentation and response procedures.
- **Snort and Nessus Documentation** – Used for understanding IDS rules, vulnerability scanning, and endpoint monitoring tools.

Conclusion

This lab provided hands-on experience with SOC monitoring and security analysis tools.
The lab demonstrated how to:

- Implement centralized log monitoring using ELK Stack
- Detect failed SSH login attempts
- Simulate brute-force attacks
- Perform vulnerability scanning using Nessus
- Detect malicious network activity using Snort

These practical exercises helped develop a deeper understanding of SOC operations, log analysis, and incident response processes.